

Kaska Exposure Management Platform™ — Technical Whitepaper

*An Autonomous Cyber Risk & Resilience Technical Architecture — Architecture,
Operating Model & Security Design*

Designed for: CISO · CTO · CRO · Security Architecture · Risk · Compliance · Enterprise Procurement ·
MSSP

Kaska Technologies & Services Pvt. Ltd.

Document Control

Field	Value
Document	Kaska Exposure Management Platform™ — Technical Whitepaper
Version	1.0
Publication	September 2026
Classification	Public / Customer-Facing
Primary Audience	CISO, CTO, CRO, Security Architecture, Risk, Compliance, Procurement
Product Scope	Exposure management, control validation, risk quantification, evidence, AI-assisted investigation and governed remediation
Positioning	AI-driven intelligence and action layer above the existing security stack

Publication principle — This whitepaper describes the product architecture and capabilities represented in the current product materials. Connector availability, control libraries, framework mappings, AI models and deployment features are release-dependent and should be confirmed against the current product matrix.

Table of Contents

1	Executive Summary
2	Product Definition and Scope
3	The Exposure Management Problem
4	Design Principles
5	Platform Operating Model
6	Reference Architecture
7	Data Ingestion and Integration Architecture
8	Asset Intelligence Foundation
9	Exposure, Control Validation and Attack-Path Analysis
10	AI and Analytics Services
11	Risk Quantification and Business Impact
12	Governed Remediation and Orchestration
13	Compliance Evidence and Assurance
14	AI Estate Governance
15	Deployment, Data Sovereignty and Multi-Tenancy
16	Platform Security Architecture
17	Target Environments and Use Cases
18	Implementation and Operating Model
19	Current Release Snapshot and Product Boundaries
20	Conclusion
21	Appendix A — Representative Integration Categories
22	Appendix B — Framework Alignment
23	Appendix C — Glossary
24	References

1. Executive Summary

Positioning: Kaska enters the market as an Exposure Management Platform while delivering the broader operating model of an Autonomous Cyber Risk & Resilience Platform.

Enterprise security teams have accumulated a large number of specialised controls: identity, endpoint, network, cloud, vulnerability management, application security, data protection, backup, SIEM/XDR, attack simulation, GRC and threat intelligence. The resulting environment is rich in telemetry but fragmented in context.

The platform is built around a simple operating loop:

Asset → Exposure → Risk → Action → Evidence → Reassessment — Every finding is tied to the assets and relationships that create it. Remediation is then verified against the resulting state so the platform can show whether exposure has changed.

Kaska is deliberately positioned as complementary infrastructure rather than a replacement for the customer's SIEM, EDR, IAM, PAM, firewall, cloud security, vulnerability management or GRC investments. Its value comes from connecting those controls into a common decision model.

The design is consistent with the resource-centric principles of NIST Zero Trust Architecture and can be used to support cybersecurity risk management activities aligned to NIST CSF 2.0. NIST describes zero trust as focusing protection on resources rather than network location, while CSF 2.0 provides a taxonomy for managing and communicating cybersecurity risk.

Kaska also supports an emerging AI-security use case: applying the same **asset**, control and **evidence** model to selected AI systems, copilots and agents. Relevant references include NIST AI RMF and OWASP's 2025 Top 10 for LLM applications.

What Kaska Is Designed to Answer

Question	Kaska Perspective
What do we have?	Unified, classified asset and identity context across connected environments.
What is exposed?	External exposure, vulnerabilities, misconfigurations, control gaps and attack paths.
Are controls working as configured?	Where direct configuration-state evidence is available, validate the observed state against defined policy expectations.
What matters most?	Prioritise by asset criticality, exposure relationships, exploitability and business context.
What should we do?	Create governed remediation cases and execute approved workflows across connected controls.
Can we prove it?	Retain evidence, timestamps, findings, actions and framework mappings for audit and management use.

2. Product Definition and Scope

2.1 Product Definition

- 1 Discover and classify assets, identities, applications, cloud resources and internet-facing exposure.
- 1 Correlate vulnerability, configuration, identity, network and security-control information.
- 1 Validate selected security-control states through direct integrations where required.
- 1 Identify attack paths and relationships that increase the likelihood or impact of compromise.
- 1 Quantify risk using business context and, where configured, **FAIR**-aligned financial models.
- 1 Map evidence and findings to supported security, regulatory and governance frameworks.
- 1 Investigate and enrich incidents using cross-domain context.
- 1 Execute governed remediation actions through policy-controlled **orchestration**.

2.2 What Kaska Does Not Replace

Kaska is not positioned as a substitute for the security controls that protect and monitor the environment. Examples include:

Existing Security Layer	Representative Products / Services
SIEM / XDR / SOAR	Microsoft Sentinel, Splunk, QRadar, Elastic, Chronicle, Cortex XDR and similar platforms
Endpoint	CrowdStrike, Microsoft Defender, SentinelOne, Trend Micro, Cortex XDR and similar platforms
Identity / PAM	Microsoft Entra ID, Active Directory, Okta, SailPoint, Saviynt, CyberArk and similar platforms
Network / ZTNA	Palo Alto Networks, Fortinet, Cisco, Check Point, Zscaler, Cloudflare and similar platforms
Cloud	AWS, Microsoft Azure, Google Cloud and their security/configuration services
Exposure / Vulnerability	Tenable, Qualys, Rapid7, EASM, BAS/CART and related platforms
Data / Recovery	DLP/DSPM, backup, encryption and key-management platforms
GRC / Assurance	ServiceNow GRC, Archer, MetricStream, VAPT and audit processes

Positioning discipline — Kaska should be sold as the layer that connects these investments into a decision and remediation model — not as another SIEM, another EDR, or another generic vulnerability scanner.

2.3 Product Boundaries

A Kaska control result is evidence-dependent. When the platform cannot observe the state required to assess a control, the correct outcome is 'Not Assessed' rather than 'Pass'. This principle is important for auditability and avoids turning missing telemetry into false assurance.

3. The Exposure Management Problem

3.1 Fragmentation Creates Context Loss

A vulnerability scanner can identify a vulnerable host. An identity platform can identify an overprivileged account. A firewall can show a permissive rule. An EDR can show endpoint exposure. A cloud platform can show an open security group. The security decision, however, depends on the relationship between these facts.

Kaska's asset graph is intended to preserve those relationships so that a security team can move from individual findings to exposure paths and business context.

3.2 Configuration Is Not the Same as Evidence of Enforcement

Security tooling commonly contains both operational events and configuration state. Events answer 'what happened'; configuration state helps answer 'what the control is configured to do'. Kaska therefore uses a dual-path ingestion model: aggregated events where the customer already has them, plus direct APIs where configuration-state validation is required.

3.3 From Vulnerability Management to Exposure Management

Exposure management expands the decision beyond CVSS severity or vulnerability count. The relevant question becomes whether an exposure can materially increase the probability or impact of compromise given the asset's business criticality, identity relationships, compensating controls and attack paths.

CISA's Internet Exposure Reduction guidance similarly emphasises discovering internet-accessible assets, determining which exposure is necessary and reducing unnecessary exposure. Kaska extends this concept across internal controls, identities, cloud, network relationships and business context.

3.4 Assurance Must Be Continuous

Point-in-time assessments remain valuable, but posture changes continuously. New assets appear, identities change, cloud policies drift, vulnerabilities emerge, controls are modified and attack paths open or close. Kaska is designed to continuously reassess the state represented by its connected data sources.

4. Design Principles

Principle	Design Interpretation
Asset-centric	All findings, relationships, controls and risk are anchored to identifiable assets or identities.
Evidence-first	A control result should reference observable evidence, source and timestamp where available.
Vendor-agnostic	The platform should remain useful as underlying security tools are added, replaced or consolidated.
Risk-contextual	Prioritisation should use more than technical severity; asset criticality, exposure relationships and business impact matter.
Governed autonomy	Automation should be configurable by action, severity and tenant, with approval gates for consequential actions.
Data-sovereign	Deployment choices should allow customers to keep sensitive security context within an approved jurisdiction or environment.
Explainable outcomes	Risk and remediation recommendations should retain the evidence and reasoning context needed for human review.
Closed-loop validation	A remediation should trigger reassessment so the platform can determine whether the relevant exposure or control gap changed.

Alignment with Industry Frameworks

Kaska does not replace a cybersecurity framework or create compliance by itself. Its control and evidence model can be mapped to frameworks used by customers. NIST CSF 2.0 is particularly useful as a communication layer because it is designed to help organisations understand, assess, prioritise and communicate cybersecurity outcomes. NIST SP 800-207 provides the Zero Trust architectural basis for a resource-centric security model.

For AI governance, NIST AI RMF provides a voluntary risk-management framework, while OWASP's 2025 LLM Top 10 provides application-security risk categories relevant to LLM and agentic systems. Kaska can map selected AI-control evidence to such references where the relevant controls and data sources are supported.

5. Platform Operating Model

The platform's operating model is intentionally simple. It turns disconnected signals and control states into a sequence of decisions and actions.

Stage	Core Processing	Result
Discover	Ingest, normalise, deduplicate and classify assets and security signals.	Asset and exposure inventory
Understand	Resolve identities, dependencies, controls, vulnerabilities and relationships.	Contextualised exposure model
Validate	Evaluate supported controls against configured policies or validation rules.	Control posture and evidence
Prioritise	Assess exploitability, business criticality, attack paths and financial/business impact.	Ranked exposure
Remediate	Create cases and run approved workflows across connected tools.	Controlled action
Verify	Re-read the relevant state and update the model.	Closed-loop assurance
Report	Generate operational, executive and compliance views.	Decision-ready reporting

Unified Working Loop

Asset → Finding → Case → Action → Evidence → Risk → Reassessment — The loop is the platform's conceptual spine. It ensures that discovery, risk analysis, remediation and evidence are not isolated functions.

Why the Asset Graph Matters

A single host can appear in SIEM, EDR, vulnerability management and cloud inventory under different identifiers. Kaska's asset-intelligence layer is intended to deduplicate those representations and attach related controls, identities, vulnerabilities and relationships to a common record.

6. Reference Architecture

The current technical design uses five logical layers. The layers are logical rather than prescriptive physical deployment tiers.

Layer	Purpose	Representative Functions
1. Data & Signal Ingestion	Bring together operational, configuration and assurance data.	SIEM/XDR, cloud APIs, identity, EASM, vulnerability, control-plane APIs, BAS/CART, VAPT and audit inputs
2. Asset Intelligence Foundation	Create the common model used by all downstream services.	Discovery, deduplication, classification, ownership, criticality, relationships, coverage and evidence
3. Kaska AI & Analytics Core	Turn raw data into prioritised insights.	Control validation, correlation, attack paths, risk quantification, threat-informed prioritisation, AI-assisted investigation
4. Orchestration & Case Management	Convert approved decisions into controlled action.	Cases, approvals, playbooks, connector actions, workflow and notification
5. Kaska Exposure & Resilience Dashboard	Present decision-ready views to operations, risk and leadership.	Exposure map, control posture, attack paths, financial risk, compliance evidence, action audit

Reference Data Flow

Existing Security Stack → Ingestion → Asset Graph → Analytics & AI → Risk / Finding → Case & Approval → Orchestration → Reassessment — The design allows Kaska to consume customer investments rather than duplicate the underlying security-control functions.

Architecture Consideration: Event Data vs Configuration State

Event aggregation is efficient for detection and correlation. Direct configuration-state integration is necessary when the question is whether a policy or control is configured and enforced. The two paths should therefore coexist rather than be treated as interchangeable.

7. Data Ingestion and Integration Architecture

7.1 Path A — Aggregated and External Data

Path A is intended for data that can be obtained through existing aggregation or external APIs. Examples include SIEM/XDR events, cloud security findings, external attack-surface data, identity information and threat intelligence.

- 1 **SIEM/XDR/SOAR/UEBA:** consume already-correlated or aggregated security events where available.
- 1 **Cloud:** discover resources and security posture through cloud-native APIs.
- 1 **External exposure:** ingest internet-facing asset and exposure intelligence.
- 1 **Threat intelligence:** enrich exposure and incident context.
- 1 **Assurance inputs:** ingest structured VAPT, audit and simulation outputs.

7.2 Path B — Direct Control-Plane Integration

Path B is used when Kaska must inspect configuration or policy state from the system that actually governs the control. Representative domains include IAM/PAM, EDR, firewalls, NAC, ZTNA/CASB, vulnerability management, backup, DLP/DSPM, application security and OT security.

7.3 Connector Model

Connector Type	Primary Need	Typical Access
Validation connector	Read control/configuration state	Prefer least-privilege, read-only credentials
Event connector	Consume security events	Read access to event/alert APIs or streams
Enrichment connector	Add business/asset/threat context	Scoped read access
Orchestration connector	Execute approved actions	Explicit, narrowly scoped write permissions
Evidence import	Bring VAPT/audit/simulation results	Structured file/API import

Integration rule — Connector names and vendor support should be published in a versioned compatibility matrix. Avoid implying that every named vendor in a category is available in every product edition.

8. Asset Intelligence Foundation

The Asset Intelligence Foundation is the platform's common system of context. It resolves multiple representations of the same asset and connects technical state to business context.

Core Asset Attributes

- 1 Asset type, hostname, identifiers and environment
- 1 Location, cloud account/subscription/project and network context
- 1 Business criticality and service ownership
- 1 Data classification and sensitivity where available
- 1 Software and hardware inventory / SBOM or related xBOM information where available
- 1 Identity and privilege relationships
- 1 Security controls protecting the asset
- 1 Vulnerabilities, exposures and open findings
- 1 Attack-path relationships and dependencies
- 1 Evidence history and remediation state

Knowledge Graph Model

Kaska represents relationships among assets, identities, controls, vulnerabilities, services, findings and business dependencies. This makes it possible to reason about a vulnerability in context — for example, whether the affected asset is internet-facing, whether a privileged identity can reach it, whether compensating controls are present, and whether the asset supports a critical business service.

Evidence Lineage

Each control or exposure result should retain source, timestamp, collection method and the relevant evidence object. This provides traceability when a CISO, auditor or remediation owner asks why a finding exists.

9. Exposure, Control Validation and Attack-Path Analysis

9.1 Exposure Management

Kaska aggregates exposure signals from external attack surface, vulnerabilities, configuration findings, identity posture, cloud posture and control-validation results. The objective is not to eliminate every finding; it is to identify the exposures that create meaningful risk and guide remediation.

9.2 Continuous Control Validation

Where supported by a direct integration, Kaska evaluates a control against a defined validation rule or policy expectation. Example domains include MFA enforcement, privileged-access governance, endpoint prevention posture, firewall segmentation, cloud security-group configuration, backup immutability and data-protection controls.

Validation should be expressed as a state such as Pass, Fail, Not Assessed or Not Applicable, with evidence attached where possible. 'Pass' means the observed evidence satisfied the configured validation rule; it does not mean that the organisation is globally secure or compliant.

9.3 Attack-Path Analysis

Attack-path analysis connects exposures and relationships to identify routes that could lead from an initial exposure to a high-value asset. Inputs may include vulnerabilities, identity permissions, network reachability, cloud configuration, security controls and asset criticality.

Paths should be recalculated as relevant source data changes. A patch, revoked privilege or corrected network rule can close a path; a new exposure can open one.

9.4 Assurance Correlation

Where attack-simulation or CART results are available, Kaska can correlate observed simulation outcomes with configuration-state findings. This creates a useful distinction between 'configured' and 'observed to block the tested technique'. The latter should only be claimed when actual test evidence is present.

10. AI and Analytics Services

Kaska uses a combination of deterministic rules, statistical analytics, graph analysis and AI services. Not every platform capability needs an LLM. This separation is important for reliability, explainability and data sovereignty.

Service	Role	Primary Output
Control Validation Engine	Evaluate observed control state against validation rules.	Control result + evidence
Correlation Analytics	Connect events and behaviours across security domains.	Correlated incident/finding
Attack-Path Analytics	Traverse asset, identity and network relationships.	Prioritised exposure path
Risk Quantification	Model loss exposure using configured risk assumptions.	ALE / VaR / risk scenarios
Business Impact Analysis	Connect technical scenarios to services and dependencies.	Business impact estimate
Threat-Informed Prioritisation	Use threat intelligence, exploitability and current posture to prioritise exposure.	Threat-priority brief
AI-Assisted Investigation	Enrich alerts, build timelines and recommend investigation/remediation steps.	Decision-ready incident context
Response Decisioning	Select an approved playbook based on incident context and policy.	Proposed/approved action sequence
AI Estate Governance	Assess selected controls around AI systems and agents.	AI-risk findings and evidence

10.1 AI-Assisted Investigation

The current design describes an investigation pipeline covering triage, contextualisation, cross-domain correlation, threat-intelligence enrichment, impact assessment, timeline reconstruction, remediation recommendation and documentation. Human review remains configurable, and consequential response actions can require explicit approval.

10.2 Threat Prediction — Recommended Terminology

For customer-facing material, Kaska should use 'threat-informed prioritisation' or 'threat-informed risk analytics' unless predictive accuracy has been independently measured and published. Forecasting a specific attack type or timing is a substantially stronger claim than prioritising current exposure using threat intelligence.

10.3 AI Model Independence

The platform should treat external LLMs as replaceable inference providers rather than as a dependency of the product's core security model. Deterministic control validation, asset correlation and policy enforcement should remain functional without an external LLM.

11. Risk Quantification and Business Impact

11.1 Why Technical Scores Are Not Enough

CVSS, severity labels and control scores are useful technical signals, but they do not directly express the potential business consequence of an exposure. Kaska therefore allows technical findings to be enriched with asset criticality, business dependencies and financial assumptions.

11.2 FAIR-Aligned Financial Risk

The current technical design describes **FAIR**-aligned analysis using factors such as threat event frequency, vulnerability probability, control effectiveness, asset value and loss magnitude, with Monte Carlo simulation to generate a distribution of possible loss outcomes.

Important risk-model boundary — Financial risk output is a model, not a prediction or guarantee of future loss. Its usefulness depends on the quality of assumptions, asset valuation, threat data and loss estimates supplied to the model.

11.3 Executive Risk Views

View	Decision Supported
Exposure by business service	Which business services have the highest concentration of cyber exposure?
Risk by asset / group	Where should remediation resources be applied first?
Scenario impact	What could a ransomware, compromise or data-exfiltration scenario cost?
Risk reduction after remediation	Did the proposed action materially reduce the modelled exposure?
Investment analysis	Which security improvement produces the greatest modelled reduction in risk for the investment?

12. Governed Remediation and Orchestration

12.1 Cases and Approvals

Kaska converts actionable findings into Cases that carry the affected assets, evidence, business context and proposed remediation. The approval workflow allows customers to define which actions can run automatically and which require a named human approval.

12.2 Response Domains

Domain	Representative Actions
Identity	Suspend account, revoke session, reset MFA, revoke tokens/keys, modify conditional access
Endpoint	Isolate host, quarantine file/process, trigger collection, initiate hunt
Network	Block IP/domain, create firewall rule, quarantine device via NAC
Cloud	Restrict security group, revoke permission, snapshot resource, restrict storage access
Workflow	Create ticket, notify team, escalate, initiate regulatory workflow where configured

12.3 Autonomy Controls

- 1 Autonomy level configurable by action type, severity and tenant.
- 1 Low-risk, reversible workflow actions may be automated.
- 1 High-impact actions can require one or more approval steps.
- 1 Every action records trigger, policy, actor/approver, target, result and timestamp.
- 1 Where technically feasible, reversal steps should be available and documented.

12.4 Auditability

The current design includes structured audit logging and optional immutable/WORM storage for environments that require it. The documentation should describe such evidence as tamper-evident or immutable according to the actual storage and cryptographic implementation; legal conclusions such as 'court-admissible' should not be made in a product datasheet.

13. Compliance Evidence and Assurance

13.1 Compliance as a Reuse Layer

Kaska can associate evidence collected during security operations with supported framework requirements. The same technical evidence may support multiple requirements, reducing duplicate collection.

13.2 What Kaska Does — and Does Not — Claim

Kaska Can	Kaska Should Not Claim
Maintain technical evidence against mapped requirements	That deployment automatically makes the organisation compliant
Show current gaps and evidence status	That every regulator will accept the same evidence package
Reuse evidence across supported mappings	That one validation effort 'satisfies every regulator'
Export audit-ready evidence packages	That Kaska replaces an independent auditor or certification process
Track remediation of mapped gaps	That a framework mapping is legal advice

13.3 Framework Alignment

The current product materials identify 17 framework mappings. These should be maintained as a versioned control-to-requirement library, with the release date, source version and mapping status documented.

Reference Family	Examples in Current Product Materials
India / Sector	RBI cybersecurity requirements, CERT-In Directions, SEBI CSCRF, IRDAI cybersecurity guidance, NCIIPC-related controls, CEA cyber-security requirements
International	ISO/IEC 27001:2022, NIST CSF 2.0, PCI DSS, SOC 2, GDPR technical safeguards, HIPAA, FISMA/NIST SP 800-53, CIS Controls
Zero Trust	NIST SP 800-207
AI Security / Governance	NIST AI RMF, OWASP LLM Top 10 (2025), MITRE ATLAS, ISO/IEC 42001, RBI FREE-AI where applicable

The mapping library should be treated as product content with its own QA process. Frameworks and regulatory requirements change, and customer applicability depends on sector, geography, scope and legal interpretation.

14. AI Estate Governance

The product materials extend the exposure-management model to AI systems, copilots, retrieval pipelines and autonomous agents. The recommended positioning is 'AI estate governance' rather than a claim that Kaska is a complete AI security platform.

Representative Control Areas

- 1 Guardrail and content-filter enforcement
- 1 Prompt-injection and jailbreak testing evidence
- 1 Sensitive-data exposure and oversharing
- 1 Model and dependency provenance / AI-BOM
- 1 Agent identity and least-privilege access
- 1 Tool and MCP allow-listing
- 1 Human approval for high-impact agent actions
- 1 Logging and red-team coverage
- 1 Shadow-AI discovery where supporting evidence is available

Reference Frameworks

Relevant references include NIST AI RMF and the OWASP Top 10 for LLM Applications 2025. OWASP's 2025 update explicitly addresses risks such as prompt injection, sensitive information disclosure, supply-chain risk, data/model poisoning and excessive agency, among others.

Recommended product-language discipline — Use 'supports mapping to', 'assesses selected controls against' and 'provides evidence relevant to' rather than 'certifies AI compliance' or 'guarantees AI safety'.

15. Deployment, Data Sovereignty and Multi-Tenancy

15.1 Deployment Options

Model	Description	Typical Environment
SaaS	Kaska-hosted service with managed platform operations.	Enterprise, mid-market, service providers
MSSP Multi-Tenant	Multi-customer operating model with tenant isolation and service-provider controls.	MSSP / MDR providers
Private Cloud	Dedicated Kaska instance in a customer-selected cloud environment or region.	BFSI and regulated enterprise
On-Premise	Customer-hosted deployment with controlled external connectivity.	Government, PSU, critical infrastructure
Air-Gapped	Customer-hosted deployment with no external network dependency and local inference options.	Defence / highly restricted environments

15.2 LLM/Data Processing Tiers

The current design describes three broad inference models: external-provider inference with data minimisation; private-cloud inference within a chosen jurisdiction; and customer-hosted inference for restricted or air-gapped environments.

Claims about data localisation should be tied to the actual deployment architecture, data flows, processor agreements and customer configuration. A product datasheet should not imply that a SaaS deployment is 'fully sovereign' merely because the primary infrastructure is in a particular region.

15.3 Multi-Tenancy

The technical design specifies tenant-scoped data access and separation at the data layer, with distinct roles for platform administration, MSSP operations, enterprise customers and proof-of-concept accounts. This should be independently tested through application security and tenant-isolation testing before being used as a contractual security claim.

16. Platform Security Architecture

Control Area	Current Design Described in Product Materials
Authentication	JWT-based authentication; short-lived access tokens; TOTP MFA for administrative roles
Authorisation	Role-based access control with hierarchical privilege boundaries
Credential protection	Integration credentials encrypted at rest; scoped connector permissions
API security	Authentication, input validation, rate limiting, restricted CORS, HTTPS and security headers
Database security	Parameterized queries and tenant-scoped access
Audit	Structured JSON logging of authentication, API requests, data access and playbook execution
Evidence integrity	WORM/immutable storage options described for selected deployments
Connector security	Least-privilege access; read-only validation connectors where possible; scoped write permissions for orchestration

Security Assurance Recommendations Before Broad Launch

- 1 Publish a Security Architecture Overview separately from the marketing whitepaper.
- 1 Complete and document SAST/DAST, dependency/SBOM scanning and penetration testing.
- 1 Perform tenant-isolation testing for MSSP deployments.
- 1 Perform connector permission review and credential-rotation testing.
- 1 Document secrets management, key management and backup/restore procedures.
- 1 Define vulnerability disclosure and security incident response processes.
- 1 Maintain a release-specific threat model and security test summary.
- 1 Only claim certifications, attestations or FIPS validation if the exact product/deployment is covered by the relevant certification.

17. Target Environments and Use Cases

Environment	Representative Need	Kaska Role
BFSI	Continuous security-control assurance, risk quantification and evidence reuse.	Exposure + control validation + risk + evidence
Healthcare	Data protection, ransomware resilience and access-control assurance.	Data/control posture + exposure + governed response
Government / PSU	Customer-hosted deployment, sovereignty and compliance evidence.	On-premise exposure management + control validation
Defence / Strategic	Restricted connectivity and local data processing.	Air-gapped exposure/control assurance where deployed
Manufacturing / OT	Asset visibility, segmentation and OT-control posture.	OT exposure and control evidence via supported integrations
MSSP	Multi-customer risk and control operations.	Tenant-isolated exposure management and service-provider workflows

Representative Use Cases

- 1 **External exposure reduction:** discover internet-facing assets, identify unnecessary exposure and prioritise remediation.
- 1 **Critical asset protection:** connect vulnerabilities, identity privileges and network reachability to identify attack paths to high-value systems.
- 1 **Control assurance:** continuously validate selected MFA, EDR, firewall, cloud, backup and data-protection controls.
- 1 **Executive risk reporting:** translate priority exposure into business-impact and financial-risk views.
- 1 **Continuous audit readiness:** maintain evidence associated with supported framework requirements as posture changes.
- 1 **Incident context and response:** enrich detections with asset, identity, exposure and business context and execute approved response playbooks.
- 1 **AI estate governance:** identify and assess selected controls around AI systems, copilots and agents.

18. Implementation and Operating Model

18.1 Recommended Deployment Sequence

- 1 Establish the asset and identity baseline using the customer's highest-value data sources.
- 2 Connect SIEM/XDR and cloud sources to obtain broad operational context with minimal deployment friction.
- 3 Add direct control-plane integrations for the security domains where configuration-state validation matters most.
- 4 Define business criticality, service ownership and risk assumptions.
- 5 Enable exposure and attack-path prioritisation.
- 6 Introduce compliance mappings and evidence workflows for the customer's initial frameworks.
- 7 Enable governed response playbooks, starting with reversible, low-risk actions.
- 8 Expand into additional domains, OT/ICS and AI estate governance as the operating model matures.

18.2 Operating Roles

Role	Typical Responsibility
CISO / Risk	Risk appetite, prioritisation, executive reporting and policy decisions
Security Architecture	Integration design, control policy and target-state architecture
SOC / Security Operations	Investigation, incident context, playbook operations and exceptions
Infrastructure / Cloud	Remediation of configuration and platform findings
IAM / PAM	Identity and privileged-access remediation
GRC / Compliance	Framework mapping, evidence review and audit coordination
Business Owner	Criticality, service dependency and risk acceptance decisions
MSSP Operator	Tenant operations, policy templates and managed remediation where applicable

19. Current Release Snapshot and Product Boundaries

19.1 Current Engineering Snapshot

The source technical whitepaper describes a current engineering snapshot of 41 application services, 18 AI/analytics engines, approximately 1,399 executed control checks across 31 domains, 225 connectors across 39 categories, mappings to 17 frameworks and approximately 7,300 automated tests. These figures are useful as engineering proof points, but they should be versioned because connector and control-library counts change over time.

19.2 Capability Claims That Should Be Controlled

Current Wording / Concept	Recommended Launch Wording
"Proves your controls can withstand it."	"Validates control state and correlates available simulation evidence where supported."
"Prevents breaches."	"Reduces exposure and helps close high-impact control and configuration gaps."
"Predicts likelihood and timing of attacks."	"Provides threat-informed prioritisation based on current exposure and intelligence."
"Satisfies every regulator."	"Maps evidence to supported framework requirements; compliance remains the customer's responsibility."
"Court-admissible evidence."	"Tamper-evident / immutable evidence storage where the deployment supports it."
"Better insurance terms / lower premiums."	"Provides evidence that can support underwriting and renewal discussions."
"No current platform provides..."	"Kaska is designed to unify..." unless independently benchmarked.
"One of the first..."	Remove unless supported by an independently verifiable market study.

19.3 Important Product Boundary

Kaska should avoid becoming a 'do everything' security platform in its launch narrative. The clearest category story is Exposure Management + Continuous Control Validation + Business Risk + Governed Remediation, with AI-assisted investigation and AI-estate governance as differentiated capabilities.

Launch message — Kaska does not ask customers to replace their security stack. It helps them understand whether that stack is creating measurable protection, where exposure remains, which risks matter most, and what to do next.

20. Conclusion

Its technical foundation is an asset-centric model supported by dual-path ingestion, control validation, exposure and attack-path analytics, risk quantification, evidence management and governed orchestration. The platform is intended to operate above existing security investments and to adapt as those investments change.

For customers, the practical objective is straightforward: reduce the exposures that matter, validate the controls that are supposed to protect critical assets, quantify risk in business terms, and maintain an evidence trail that can be used by security, risk, compliance and leadership.

Kaska — Know what you have. Know what is exposed. Know which controls matter. Know what to do next.

Appendix A — Representative Integration Categories

Category	Representative Examples from Current Product Materials
SIEM / XDR / SOAR / UEBA	Microsoft Sentinel, Splunk, IBM QRadar, Cortex XDR, ArcSight, Elastic Security, Chronicle, Defender XDR, Sumo Logic, LogRhythm
IAM / Identity	Active Directory, Microsoft Entra ID, Okta, SailPoint, Saviynt, Ping Identity, Google Workspace, OneLogin
PAM	CyberArk, Arcon, ManageEngine PAM360
EDR	CrowdStrike Falcon, SentinelOne, Microsoft Defender for Endpoint, Trend Micro, Carbon Black, Cortex XDR
Network / Firewall / ZTNA	Palo Alto Networks, Fortinet, Cisco, Check Point, Zscaler, Cloudflare, Aruba, ForeScout
Cloud	AWS, Microsoft Azure, Google Cloud
Vulnerability	Tenable, Qualys, Rapid7
Attack Simulation / CART	SafeBreach, AttackIQ, Cymulate, Picus, Pentera, XM Cyber
EASM / Exposure	CyCognito, Randori, UpGuard, Censys, Cortex Xpanse, Tenable.asm, Qualys EASM
Data / DLP / DSPM	Forcepoint DLP, Microsoft Purview, Symantec DLP
Backup / Recovery	Veeam, Commvault, Rubrik
GRC	ServiceNow GRC, RSA Archer, MetricStream
OT / ICS	Claroty, Dragos, Nozomi Networks, Honeywell Forge
AI Security / AI Governance	Palo Alto AIRS, Lakera, Protect AI, HiddenLayer, Prompt Security, Cisco AI Defense, Wiz AI-SPM, Microsoft Defender for AI; selected cloud AI controls and red-team evidence

This appendix is illustrative, based on the current source whitepaper. It is not a guarantee of current connector availability, certification, commercial inclusion or feature parity. Use the release-specific compatibility matrix for procurement.

Appendix B — Framework Alignment

Reference	How Kaska Can Relate	Boundary
NIST CSF 2.0	Communicate exposure, control and response outcomes within a recognised cybersecurity risk taxonomy.	CSF is not a certification; customer implementation determines outcomes.
NIST SP 800-207	Use resource-centric identity, device, network and policy concepts to structure control validation.	Kaska is not itself a Zero Trust architecture implementation.
ISO/IEC 27001:2022	Provide technical evidence and monitoring inputs relevant to selected Annex A controls.	Does not replace an ISMS, certification body or audit.
PCI DSS	Map selected technical controls and evidence to supported requirements.	Scope and applicability are customer-specific.
CIS Controls v8	Prioritise and evidence technical safeguards where mappings are implemented.	Not a substitute for full CIS implementation.
OWASP LLM Top 10 (2025)	Map selected AI application security findings and testing evidence.	Coverage depends on AI architecture and available evidence.
NIST AI RMF	Organise selected AI governance evidence around AI risk management concepts.	AI RMF is voluntary; Kaska does not certify AI systems.
MITRE ATT&CK / ATT&CK for ICS	Contextualise attack paths, simulation results and control coverage using adversary techniques.	Technique coverage depends on available telemetry and tests.

India-Specific References

The current product materials include RBI-related controls, CERT-In Directions, SEBI CSCRF, IRDAI cybersecurity guidance, NCIIPC-related controls, DPDPA-related technical safeguards and CEA cybersecurity requirements. These should be maintained as versioned mappings and reviewed whenever the underlying regulation or guidance changes.

As of September 2026, the Central Electricity Authority's official site lists a Cyber Security Regulations notification dated 12 August 2026. The product documentation should therefore avoid describing CEA cybersecurity requirements as merely a future or April-2026 draft requirement and should reference the applicable current notification/version used by Kaska's mapping library.

CERT-In's 2022 Directions include a requirement for relevant entities to maintain ICT-system logs securely for a rolling 180 days within Indian jurisdiction. Kaska documentation should describe any automated evidence/reporting around this requirement only to the extent the current implementation actually supports it.

The RBI's FREE-AI material is a committee framework/report rather than a generic substitute for sector-specific regulatory requirements; product language should therefore use 'alignment/support' rather than 'compliance certification'.

The Digital Personal Data Protection Act, 2023 is the statutory foundation for India's digital personal-data regime. Kaska can support technical control evidence relevant to data protection, but product documentation should avoid presenting technical mappings as legal advice or as proof of full statutory compliance.

Appendix C — Glossary

Term	Meaning in this Whitepaper
Exposure	A condition that can increase the likelihood or impact of compromise, including external exposure, vulnerabilities, misconfiguration, excessive privilege or control gaps.
Asset-centric	A model in which findings and relationships are anchored to identifiable assets, identities or services.
Control validation	Evaluation of an observed security-control state against a defined policy or validation rule.
Attack path	A chain of relationships and exposures that may allow an adversary to move from an initial condition toward a target asset.
EASM	External Attack Surface Management.
BAS / CART	Breach and Attack Simulation / Continuous Automated Red Teaming.
CRQ	Cyber Risk Quantification; in Kaska, financial or business-risk modelling.
ALE	Annualized/Annual Loss Expectancy, used here as a risk-model output subject to assumptions.
VaR	Value at Risk, a statistical risk measure subject to model assumptions and confidence level.
WORM	Write Once Read Many; immutable storage semantics where supported by the selected implementation.
xBOM	A broad term for software, hardware and related bill-of-materials representations.
AI Estate	The organisation's deployed AI systems, models, copilots, agents, retrieval pipelines and related supporting controls.

References

- 1 NIST CSF 2.0 — Cybersecurity Framework 2.0 (2024) —
<https://www.nist.gov/publications/nist-cybersecurity-framework-csf-20>
- 1 NIST SP 800-207 — Zero Trust Architecture — <https://csrc.nist.gov/pubs/sp/800/207/final>
- 1 NIST AI RMF 1.0 —
<https://www.nist.gov/publications/artificial-intelligence-risk-management-framework-ai-rmf-10>
- 1 OWASP Top 10 for LLM Applications 2025 —
<https://genai.owasp.org/resource/owasp-top-10-for-llm-applications-2025/>
- 1 MITRE ATT&CK — <https://attack.mitre.org/>
- 1 ISO/IEC 27001:2022 — <https://www.iso.org/standard/27001>
- 1 CISA Internet Exposure Reduction Guidance —
<https://www.cisa.gov/resources-tools/resources/exposure-reduction>
- 1 CERT-In Directions 2022 — https://www.cert-in.org.in/PDF/CERT-In_Directions_70B_28.04.2022.pdf
- 1 CEA Cyber Security Regulations notification — <https://cea.nic.in/notification/cyber-security-regulations/>
- 1 India Digital Personal Data Protection Act, 2023 —
<https://www.meity.gov.in/static/uploads/2024/02/Digital-Personal-Data-Protection-Act-2023.pdf>

Kaska Technologies & Services Pvt. Ltd. | Product capabilities, connector availability, framework mappings and deployment features are release-dependent and should be confirmed for each deployment.

© 2026 Kaska Technologies and Services. Kaska™, Kaska EM™, Kaska Exposure Management™.